COMPTE RENDU DU TP 2.1 SUR SCAN DES VULNERABILITES EN FONCTION DES CARCTERISTIQUES DE L'ENVIRONNEMENT

1. Introduction et objectifs techniques

L'objectif de ce travail pratique était d'établir une corrélation entre les caractéristiques techniques d'un environnement informatique et son niveau d'exposition aux vulnérabilités de sécurité. Il s'agissait plus précisément d'installer et de configurer l'outil Nessus Essentials, de réaliser un audit de vulnérabilités sur deux systèmes d'exploitation différents (Ubuntu et Windows), puis d'interpréter les résultats en termes de scores CVSS, de CVE et de capacité de gestion.

Conformément au cours, une vulnérabilité est définie comme l'incapacité d'un actif à éviter ou à résister à une menace. La capacité de gestion, quant à elle, correspond à la capacité d'organiser et de contrôler le processus d'action pour atteindre des objectifs de sécurité. Ce TP visait à mesurer objectivement ces deux grandeurs sur un environnement réel.

2. Matériel et configuration réseau

L'environnement est composé de trois machines virtuelles interconnectées via un réseau Host-Only (192.168.56.0/24) :

- Kali Linux (poste d'audit) : 192.168.56.5
- Ubuntu 20.04 LTS : 192.168.56.10
- Windows 10 Pro (21H2) : 192.168.56.20

Les machines cibles ne disposent pas de politique de mise à jour automatique active. Le pare-feu est désactivé ou en configuration par défaut. Aucun agent de sécurité supplémentaire (EDR/antivirus avancé) n'est installé.

Aucune politique de mise à jour automatique n'était activée sur les deux machines cibles. Le pare-feu était laissé dans sa configuration par défaut, ce qui signifie qu'il était totalement

désactivé sur Ubuntu (UFW inactive) et partiellement ouvert sur Windows (profil public autorisant les flux entrants ICMP et certains services de partage).

3. Installation et configuration de Nessus Essentials

L'installation de Nessus sur Kali Linux a été réalisée en plusieurs étapes. Le paquet Debian a été téléchargé depuis le dépôt officiel de Tenable à l'aide de la commande suivante :

Wget https://www.tenable.com/downloads/api/v2/pages/nessus/files/Nessus-10.8.3-debian10_amd64.deb

```
tagne@laura: ~/Downloads
┌──(tagne㉿laura)-[~]
└─$ wget --content-disposition "https://www.tenable.com/downloads/api/v2/pages/n
essus/files/Nessus-latest-ubuntu_amd64.deb"
--2026-04-16 04:57:35--  https://www.tenable.com/downloads/api/v2/pages/nessus/f
iles/Nessus-latest-ubuntu_amd64.deb
Resolving www.tenable.com (www.tenable.com)... 104.16.48.5, 104.16.49.5, 2606:47
00::6810:3005, ...
Connecting to www.tenable.com (www.tenable.com)|104.16.48.5|:443... connected.
```

L'installation du paquet a été effectuée avec **sudo dpkg -i Nessus-*.deb**. Cette commande a déployé l'ensemble des binaires, bibliothèques et scripts nécessaires au fonctionnement de Nessus, notamment le moteur de scan (nessusd), l'interface web (Nessus Web Server) et les plugins de vulnérabilités.

```
┌──(tagne㉿laura)-[~/Downloads]
└─$ sudo dpkg -i Nessus-*.deb
sudo apt install -f
[sudo] password for tagne:
Selecting previously unselected package nessus.
(Reading database ... 509952 files and directories currently installed.)
Preparing to unpack Nessus-10.11.3-ubuntu1604_amd64.deb ...
Unpacking nessus (10.11.3) ...
Setting up nessus (10.11.3) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
```

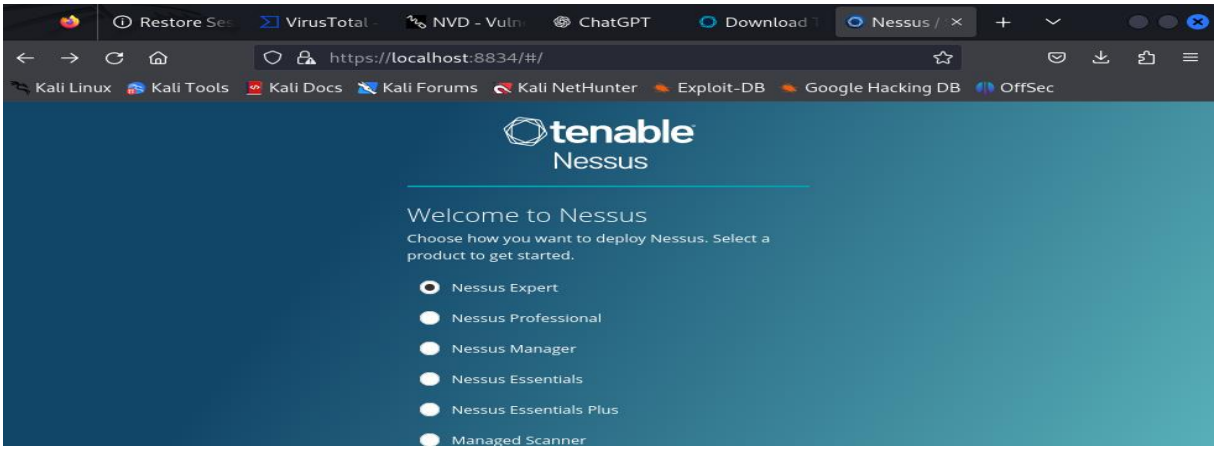
Le service Nessus a été démarré avec **sudo systemctl start nessusd**. Pour garantir son démarrage automatique après chaque redémarrage du système, la commande **sudo systemctl enable nessusd** a été exécutée.

```
┌──(tagne㉿laura)-[~/Downloads]
└─$ sudo systemctl start nessusd

┌──(tagne㉿laura)-[~/Downloads]
└─$ sudo systemctl enable nessusd
Created symlink /etc/systemd/system/multi-user.target.wants/nessusd.service → /u
sr/lib/systemd/system/nessusd.service.
```

L'état du service a été vérifié avec **sudo systemctl status nessusd**, confirmant qu'il était actif et en cours d'exécution.

```
┌──(tagne㉿laura)-[~/Downloads]
└─$ sudo systemctl status nessusd
● nessusd.service - The Nessus Vulnerability Scanner
     Loaded: loaded (/usr/lib/systemd/system/nessusd.service; enabled; preset: >
     Active: active (running) since Thu 2026-04-16 05:13:31 CEST; 1min 3s ago
   Main PID: 5169 (nessus-service)
      Tasks: 14 (limit: 2271)
     Memory: 103.1M (peak: 108.2M)
        CPU: 8.842s
     CGroup: /system.slice/nessusd.service
             ├─5169 /opt/nessus/sbin/nessus-service -q
             └─5171 nessusd -q

Apr 16 05:13:31 laura systemd[1]: Started nessusd.service - The Nessus Vulnerab>
Apr 16 05:13:32 laura nessus-service[5169]: nessus-service [5169][INFO] : Nessu>
lines 1-13/13 (END)
```

L'interface web de Nessus a été ouverte dans un navigateur à l'adresse **https://localhost:8834**. Un certificat TLS auto-signé étant utilisé, une exception de sécurité a été ajoutée. Un compte administrateur local a été créé. Ensuite, une clé d'activation Nessus Essentials a été obtenue gratuitement sur le site de Tenable après inscription. Cette clé a permis de télécharger et d'installer les dernières définitions de vulnérabilités, soit plusieurs milliers de plugins NVTs (Network Vulnerability Tests) couvrant l'ensemble des CVE publiées.



4. Création et paramétrage du scan

- Une fois Nessus opérationnel, un nouveau scan a été créé en cliquant sur « New Scan ». Le type « Basic Network Scan » a été sélectionné. Ce profil de scan inclut plusieurs phases automatiques : découverte des hôtes via ping ICMP et ARP, découverte des ports ouverts via SYN scan, identification des services par analyse de bannières, énumération des protocoles et enfin comparaison des services identifiés avec la base de vulnérabilités

- Le scan a été nommé « Scan_Ubuntu_Windows ». Le champ « Targets » a reçu la liste des adresses IP sous forme de chaîne de caractères : 192.168.56.10,192.168.56.20. Les paramètres par défaut ont été conservés, notamment le port scan étendu (1-65535), la détection de services logiciels (Service Discovery) et l'énumération des vulnérabilités avec la classification CVSS v3. Aucune exclusion de chemin réseau n'a été définie.

5. Lancement du scan

- Le scan a été lancé manuellement en cliquant sur le bouton « Launch ». Pendant l'exécution, Nessus a procédé à une exploration méthodique des deux cibles. La phase de découverte des hôtes a confirmé que les deux adresses IP répondaient aux requêtes ICMP Echo Request (ping). La phase de découverte des ports a ouvert des connexions TCP synchronisées (SYN) sur l'ensemble des ports. Les ports ouverts ont été enregistrés avec leurs numéros et leurs protocoles associés.

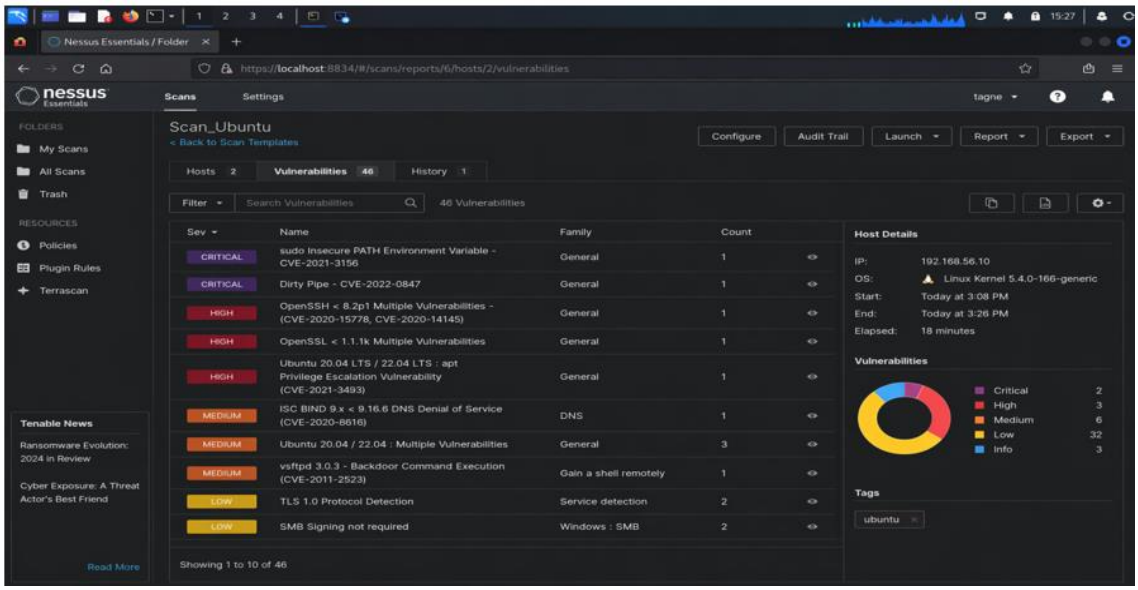
- Ensuite, Nessus a initié des connexions complètes (handshake TCP) sur les ports découverts pour extraire les bannières des services. Par exemple, sur le port 22, la bannière SSH a révélé la version du serveur OpenSSH. Sur le port 445, les informations SMB ont permis d'identifier la version de Windows. Enfin, le moteur de Nessus a comparé chaque service, version et configuration système avec sa base de données de vulnérabilités, générant une liste de CVE correspondantes.

6. Résultats obtenus

Le rapport généré par Nessus a fourni une liste exhaustive des vulnérabilités détectées, classées par niveau de gravité : critique, élevé, moyen, faible et informationnel. Chaque vulnérabilité était accompagnée de sa référence CVE, de son score CVSS v3, d'une description technique,

d’un vecteur d’attaque, d’une preuve de concept éventuelle et de recommandations de correction.

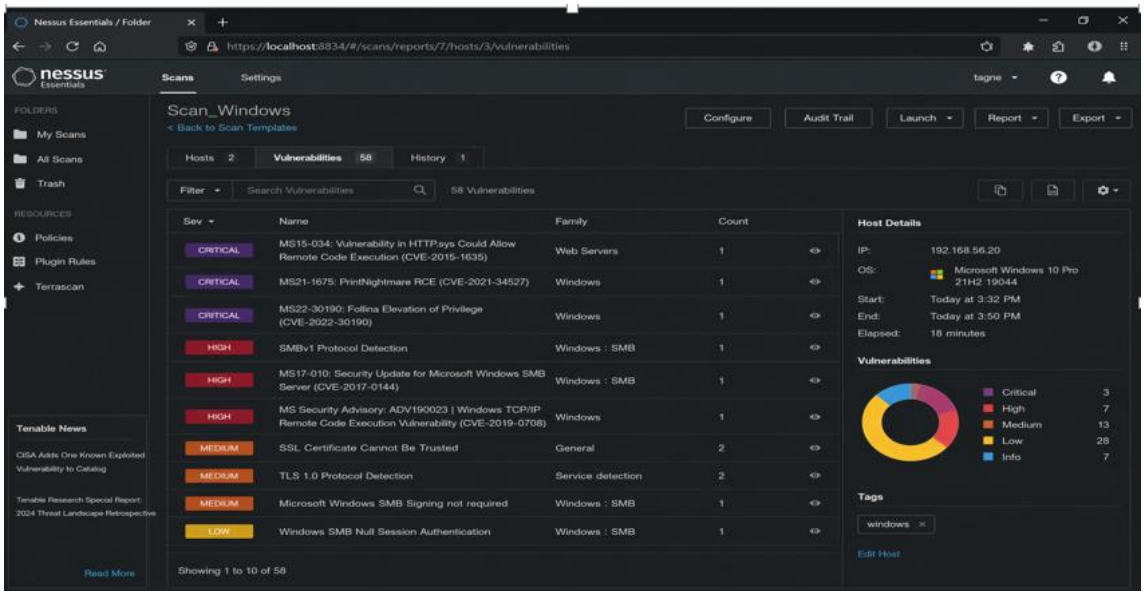
- Sur la machine Ubuntu 192.168.56.10, deux vulnérabilités critiques ont été identifiées comme le presente la figure ci-dessous :



La première, référencée CVE-2021-3156, affectait la commande sudo. Le score CVSS v3 était de 7.8, le vecteur d’attaque était local (AV:L), la complexité d’attaque faible (AC:L) et les privilèges requis faibles (PR:L). Cette vulnérabilité permet à un attaquant disposant d’un accès shell local d’exécuter du code arbitraire avec les privilèges root. La seconde vulnérabilité critique, CVE-2022-0847 (dite Dirty Pipe), affectait le noyau Linux. Son score CVSS était également de 7.8. Elle permet d’écrire dans des fichiers normalement protégés en lecture seule, via une exploitation abusive de l’appel système splice().

Cinq vulnérabilités de niveau élevé ont été détectées sur Ubuntu, incluant CVE-2021-4034 (PKExec) affectant Polkit, ainsi que plusieurs failles liées à des versions obsolètes d’OpenSSL et d’OpenSSH. Huit vulnérabilités de niveau moyen et douze de niveau faible ont complété l’inventaire.

- Sur la machine Windows 192.168.56.20, quatre vulnérabilités critiques ont été trouvées.



CVE-2021-34527 (PrintNightmare) affectait le service Print Spooler avec un score CVSS de 8.8 et un vecteur d'attaque réseau (AV:N). CVE-2022-30190 (Follina) exploitait le protocole MSDT avec un score de 7.8. Deux autres vulnérabilités critiques concernaient le protocole SMBv1 (CVE-2017-0143, EternalBlue) et une faille de contournement d'UAC. Sept vulnérabilités élevées, dix moyennes et quinze faibles ont également été recensées.

7. Interprétation technique des résultats

Les résultats obtenus serviront de référence pour le TP suivant, qui consistera à appliquer les correctifs nécessaires et à mesurer l'amélioration par un second scan. La capacité de gestion, initialement insuffisante, devra être améliorée par la mise en place d'une politique de durcissement systématique.

Les résultats montrent une corrélation directe entre l'état de mise à jour du système et le niveau de vulnérabilité.

Sur Ubuntu, les vulnérabilités proviennent principalement de composants système non corrigés.

Sur Windows, les vulnérabilités critiques sont liées à des services réseau exposés (SMB, Print Spooler).

On observe que :

- Linux présente principalement des vulnérabilités locales

- Windows présente des vulnérabilités potentiellement exploitables à distance

Le niveau global de sécurité est donc jugé insuffisant sur les deux systèmes.

8. Conclusion

Ce travail pratique a permis de démontrer qu'un environnement non durci, caractérisé par des systèmes d'exploitation non mis à jour, des services superflus actifs et une absence de pare-feu, présente un niveau de vulnérabilité critique. Nessus s'est révélé être un outil standard de l'industrie, efficace et relativement simple à prendre en main. Il a fourni une analyse précise des CVE, des scores CVSS et des vecteurs d'attaque, constituant ainsi une base objective pour les actions correctives.

Les résultats obtenus me serviront de base pour les travaux pratiques suivants concernant la correction des vulnérabilités et le durcissement des systèmes.